
ACT. 04

UNA PÁGINA DEMASIADO CONVINCENTE

Universidad Politécnica de San Luis Potosí
CNO IV: Seguridad Informática

Mtro. Servando López Contreras

Alumna: Fabiola Calvillo Galván 182455

Otoño 2026

OBJETIVO DE LA ACTIVIDAD

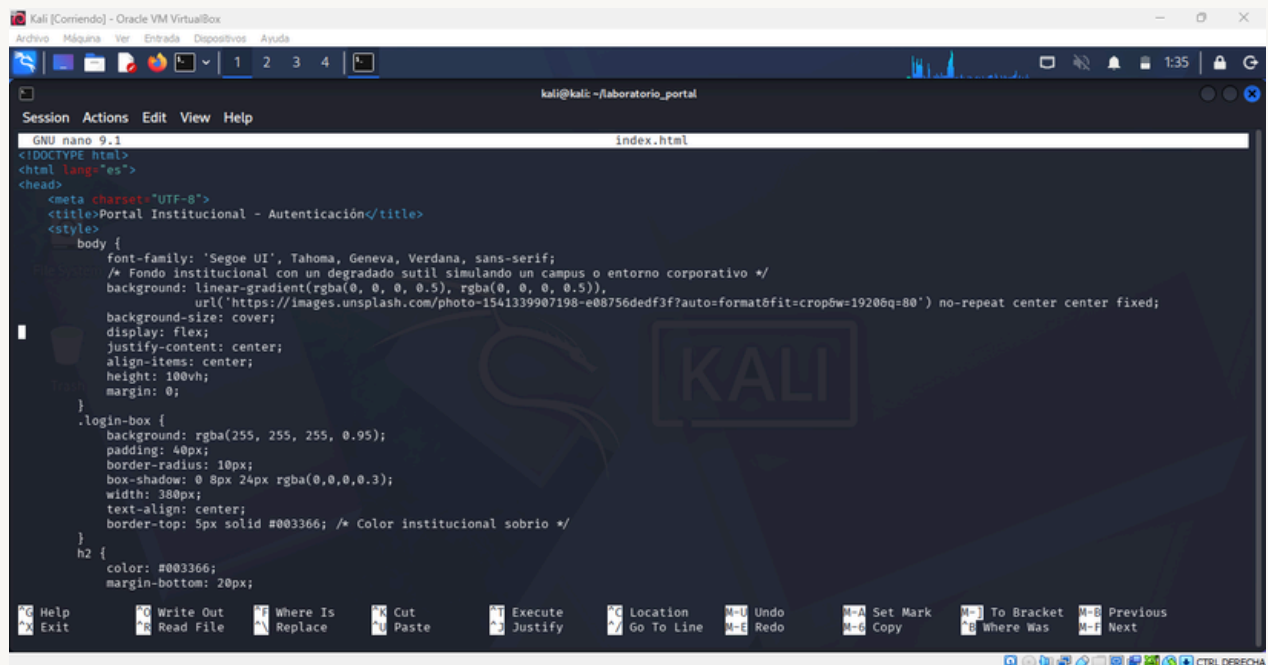
El objetivo de esta actividad más allá de saber como “hacer phishing” es saber entender como funciona, para poder defendernos en caso de que se llegue a presentar una situación como esta. Con esta actividad podemos entender de manera más profunda el como se hacen las capturas de datos desde una página que parece legítima.

Gracias a esta actividad, en un futuro sabremos como identificar de mejor manera el phishing por que ya sabemos como construir uno.

DESCRIPCIÓN DEL ESCENARIO

En este caso estaremos realizando una página que se parezca al inicio de sesión de alguna institución de estudios, esto para hacer una demostración al hacer un inicio de sesión en este tipo de páginas.

En un inicio creamos una carpeta llamada laboratorio_portal, en el cual realizamos un código html, para poder hacer el formulario y que este se vea como una página web



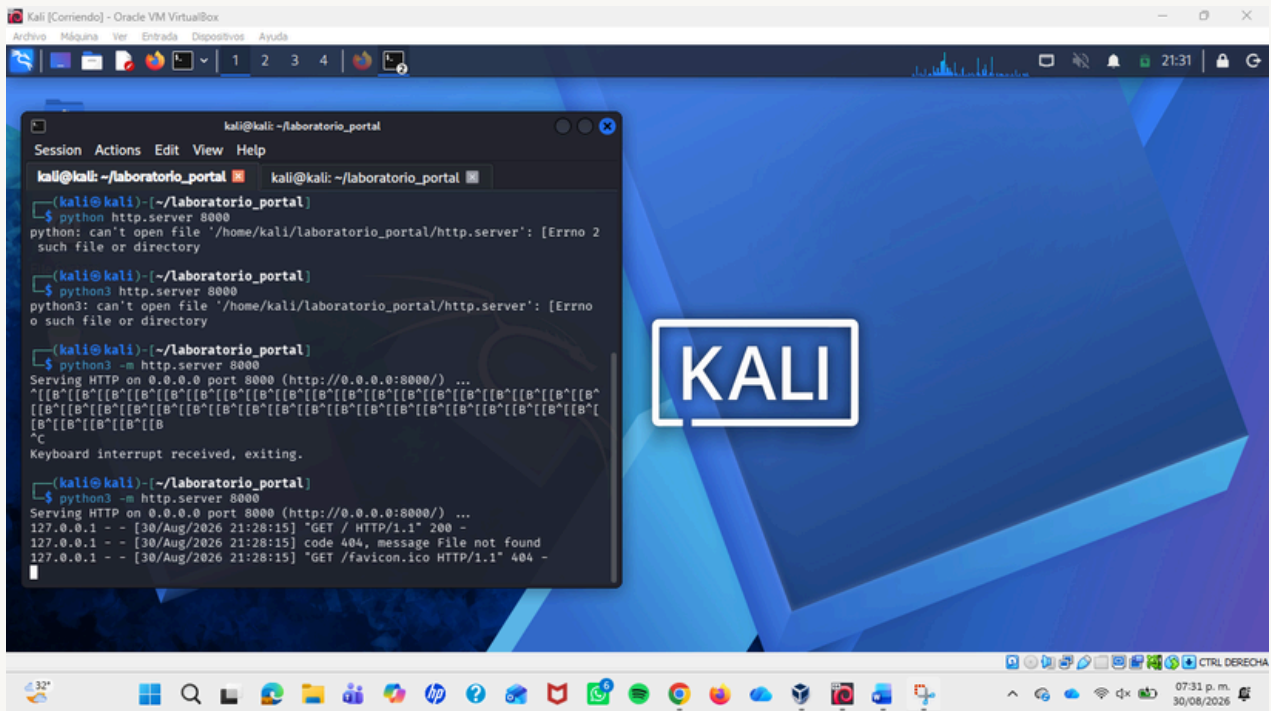
```
Kali [Corriendo] - Oracle VM VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda

kali@kali:~/laboratorio_portal

Session Actions Edit View Help

GNU nano 9.1 index.html
<!DOCTYPE html>
<html lang="es">
<head>
  <meta charset="UTF-8">
  <title>Portal Institucional - Autenticación</title>
  <style>
    body {
      font-family: 'Segoe UI', Tahoma, Geneva, Verdana, sans-serif;
      /* Fondo institucional con un degradado sutil simulando un campus o entorno corporativo */
      background: linear-gradient(rgba(0, 0, 0, 0.5), rgba(0, 0, 0, 0.5)),
        url('https://images.unsplash.com/photo-1541339907198-e08756dedf3f?auto=format&fit=crop&w=1920&q=80') no-repeat center center fixed;
      background-size: cover;
      display: flex;
      justify-content: center;
      align-items: center;
      height: 100vh;
      margin: 0;
    }
    .login-box {
      background: rgba(255, 255, 255, 0.95);
      padding: 40px;
      border-radius: 10px;
      box-shadow: 0 8px 24px rgba(0,0,0,0.3);
      width: 380px;
      text-align: center;
      border-top: 5px solid #003366; /* Color institucional sobrio */
    }
    h2 {
      color: #003366;
      margin-bottom: 20px;
    }
  </style>
</head>
<body>
  <h2></h2>
  <div class="login-box">
    <div></div>
  </div>
</body>
</html>
```

Después dentro de la terminal, en la misma carpeta de laboratorio_portal, ejecutamos el comando `python3 -m http.server` y el número de puerto que estemos utilizando, en este caso se utilizará el 8000, se está utilizando este puerto ya que normalmente se utiliza para realizar trabajos locales, entonces funciona perfecto para la actividad. Esto con la finalidad de poder subir al servidor nuestra página web.

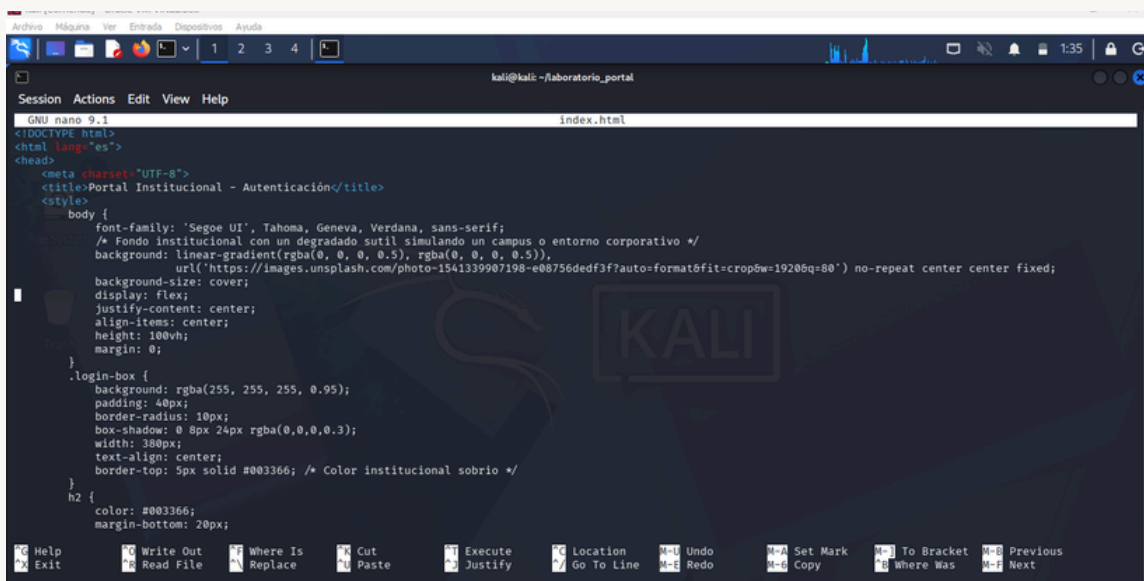


```
kali@kali: ~/laboratorio_portal
$ python http.server 8000
python: can't open file '/home/kali/laboratorio_portal/http.server': [Errno 2]
such file or directory

(kali@kali)~/laboratorio_portal
$ python3 http.server 8000
python3: can't open file '/home/kali/laboratorio_portal/http.server': [Errno
o such file or directory

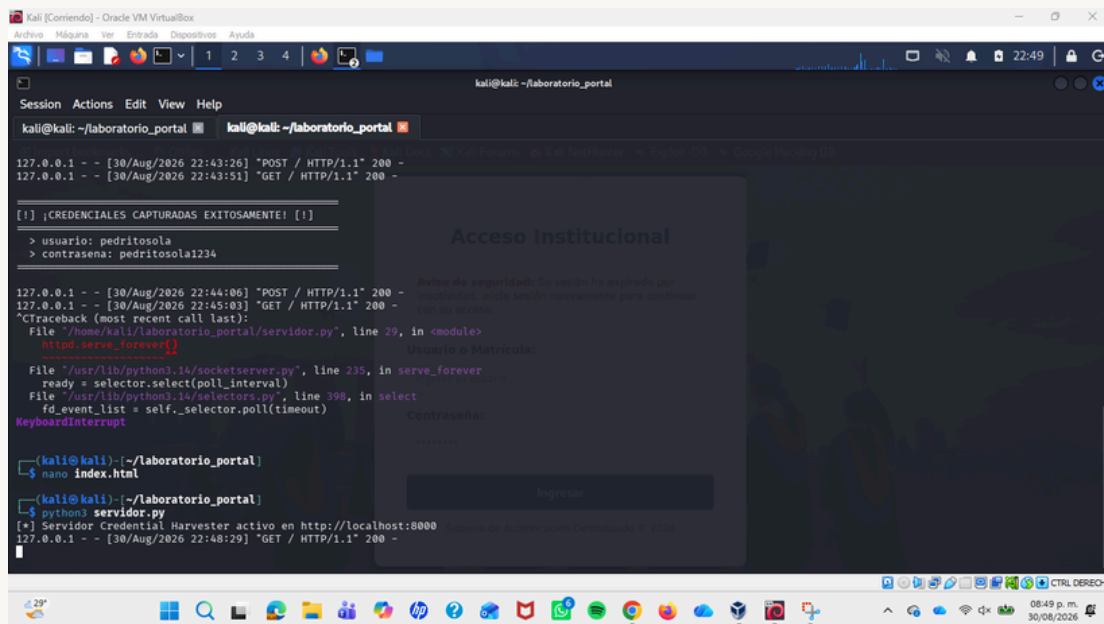
(kali@kali)~/laboratorio_portal
$ python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
127.0.0.1 - - [30/Aug/2026 21:28:15] "GET / HTTP/1.1" 200 -
127.0.0.1 - - [30/Aug/2026 21:28:15] code 404, message File not found
127.0.0.1 - - [30/Aug/2026 21:28:15] "GET /favicon.ico HTTP/1.1" 404 -
```

También se realizó un script llamado `servidor.py`, el que nos ayudaba a tener una visualización de como funciona realmente nuestra página para poder resguardar las credenciales que se llegaban a ingresar.



```
GNU nano 9.1 index.html
<!DOCTYPE html>
<html lang="es">
<head>
  <meta charset="UTF-8">
  <title>Portal Institucional - Autenticación</title>
  <style>
    body {
      font-family: 'Segoe UI', Tahoma, Geneva, Verdana, sans-serif;
      /* Fondo institucional con un degradado sutil simulando un campus o entorno corporativo */
      background: linear-gradient(to top right, #000080 49%, #000080 49%, #000080 51%, #000080 51%, #000080 53%, #000080 53%, #000080 55%, #000080 55%, #000080 57%, #000080 57%, #000080 59%, #000080 59%, #000080 61%, #000080 61%, #000080 63%, #000080 63%, #000080 65%, #000080 65%, #000080 67%, #000080 67%, #000080 69%, #000080 69%, #000080 71%, #000080 71%, #000080 73%, #000080 73%, #000080 75%, #000080 75%, #000080 77%, #000080 77%, #000080 79%, #000080 79%, #000080 81%, #000080 81%, #000080 83%, #000080 83%, #000080 85%, #000080 85%, #000080 87%, #000080 87%, #000080 89%, #000080 89%, #000080 91%, #000080 91%, #000080 93%, #000080 93%, #000080 95%, #000080 95%, #000080 97%, #000080 97%, #000080 99%, #000080 99%, #000080 100%);
      background-size: cover;
      display: flex;
      justify-content: center;
      align-items: center;
      height: 100vh;
      margin: 0;
    }
    .login-box {
      background: rgba(255, 255, 255, 0.95);
      padding: 40px;
      border-radius: 10px;
      box-shadow: 0 8px 24px rgba(0,0,0,0.3);
      width: 380px;
      text-align: center;
      border-top: 5px solid #003366; /* Color institucional sobrio */
    }
    h2 {
      color: #003366;
      margin-bottom: 20px;
    }
  </style>
</head>
<body>
  <h2></h2>
</body>
</html>
```

Se ejecutó este script para hacer la demostración y podemos observar que está esperando a que se ingrese algo.



```
Kali [Corriendo] - Oracle VM VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda

kali@kali: ~/laboratorio_portal
Session Actions Edit View Help

kali@kali: ~/laboratorio_portal
127.0.0.1 - - [30/Aug/2026 22:43:26] "POST / HTTP/1.1" 200 -
127.0.0.1 - - [30/Aug/2026 22:43:51] "GET / HTTP/1.1" 200 -

[!] ¡CREDENCIALES CAPTURADAS EXITOSAMENTE! [!]

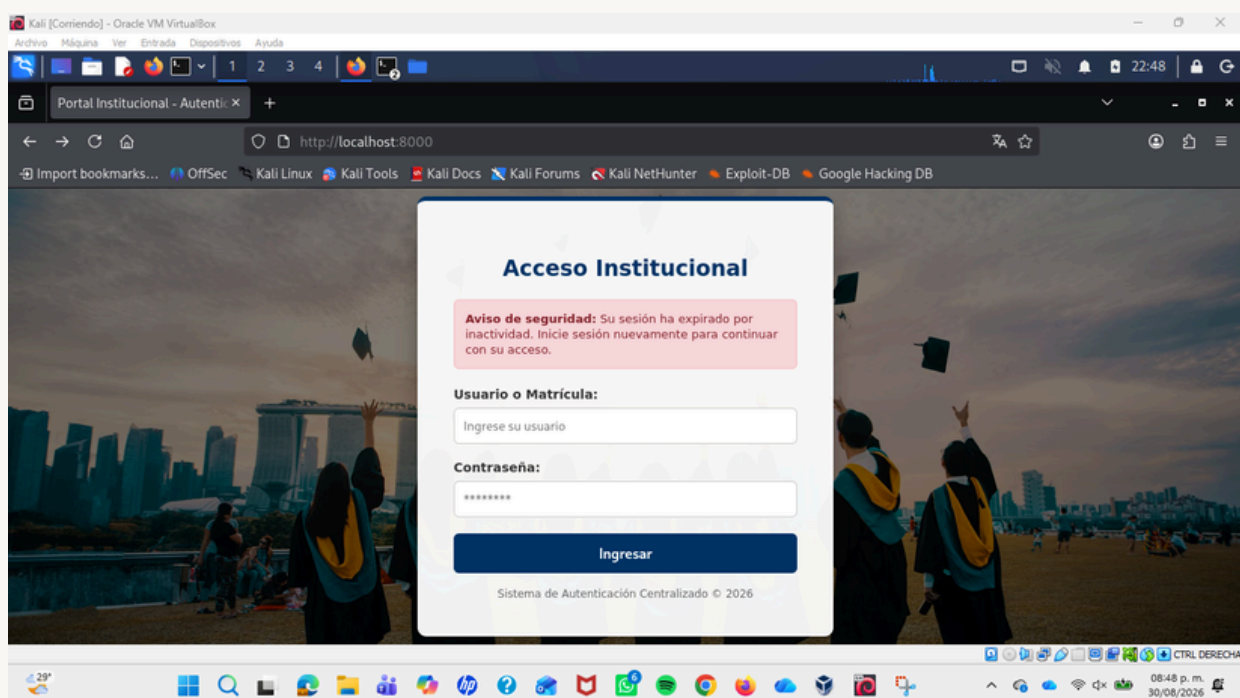
> usuario: pedritosola
> contraseña: pedritosola1234

127.0.0.1 - - [30/Aug/2026 22:44:06] "POST / HTTP/1.1" 200 -
127.0.0.1 - - [30/Aug/2026 22:45:03] "GET / HTTP/1.1" 200 -
^C[Traceback (most recent call last):
  File "/home/kali/laboratorio_portal/servidor.py", line 29, in <module>
    httpd.server_forever()
  File "/usr/lib/python3.14/socketserver.py", line 235, in serve_forever
    ready = selector.select(poll_interval)
  File "/usr/lib/python3.14/selectors.py", line 398, in select
    fd_event_list = self._selector.poll(timeout)
KeyboardInterrupt

(kali@kali)~/laboratorio_portal
$ nano index.html

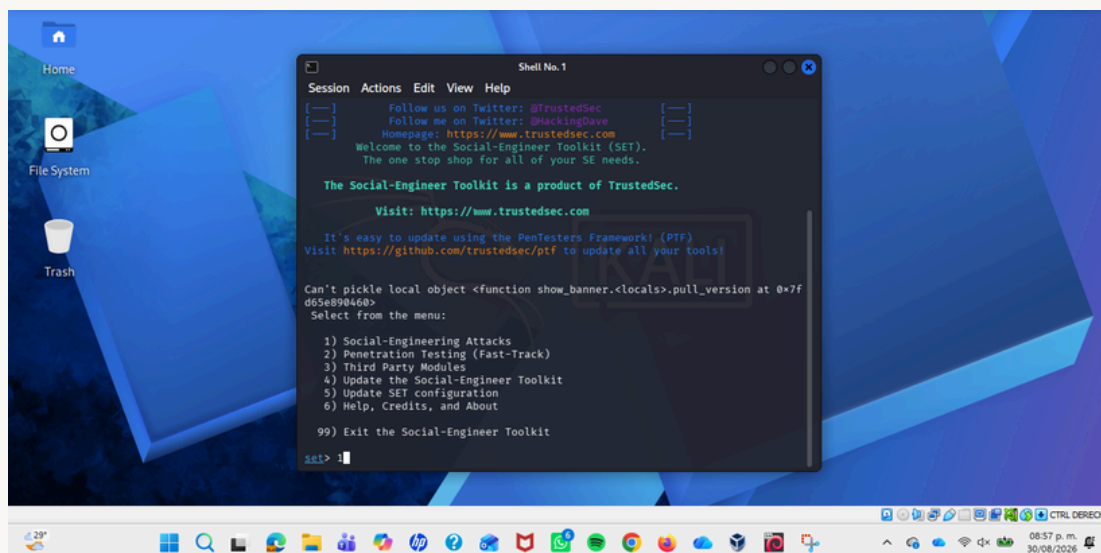
(kali@kali)~/laboratorio_portal
$ python3 servidor.py
[*] Servidor Credential Harvester activo en http://localhost:8000
127.0.0.1 - - [30/Aug/2026 22:48:29] "GET / HTTP/1.1" 200 -
```

Ahora ingresamos a nuestra página web, que desde aquí podemos empezar a identificar algunos factores para saber que es Phishing. Comenzamos con el URL de nuestra página, se muestra que es un localhost, que en algunos casos se utilizan este tipo de URL, otro aspecto es que no se encuentra ningún logo oficial, lo que también lo hace sospechoso. Lo que podría hacernos confiar más es que hay una especie de “certificación de autenticación”.

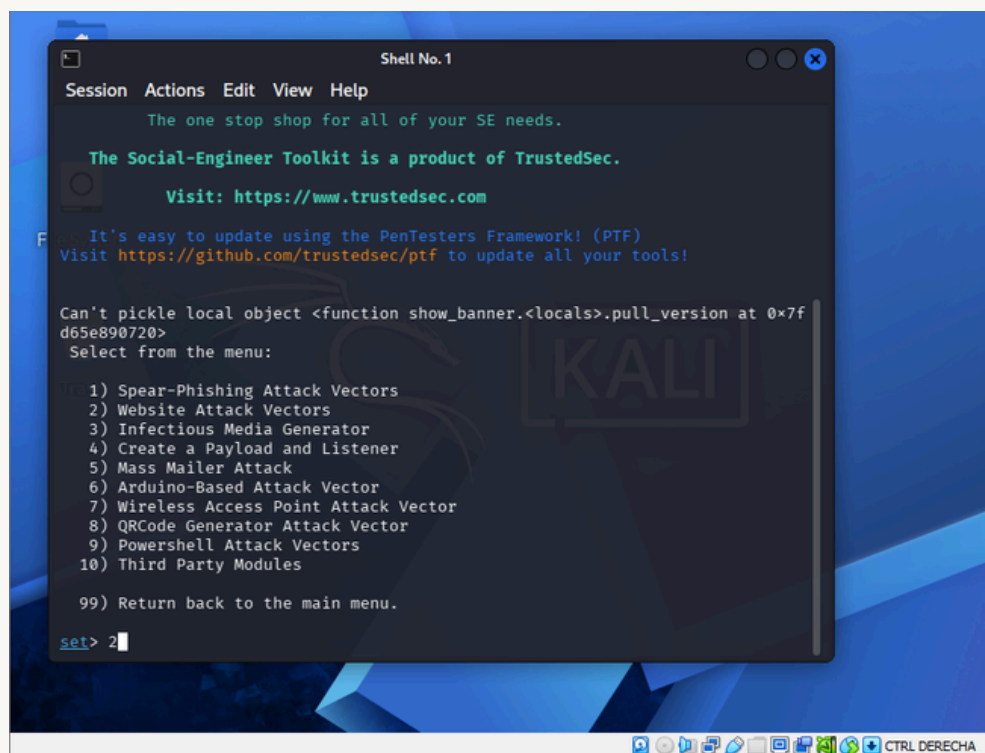


Ahora empezamos a configurar el Social-Engineer Toolkit (SET), que el SET es un conjunto de herramientas de código abierto, basado en python que automatiza pruebas de penetración enfocadas en la ingeniería social. Que la ingeniería social es una técnica de manipulación psicológica, utilizada para que se cometa un error humano para comprometer su seguridad.

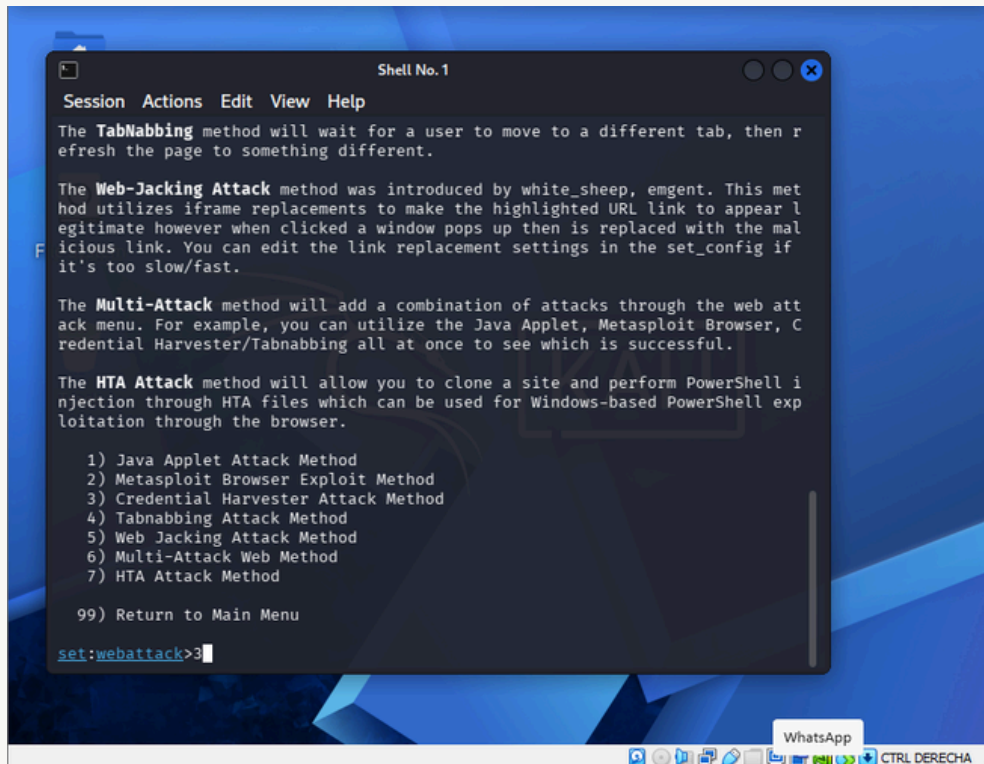
Primero, se muestra un menú y seleccionamos la primera opción, la cual es Ataques de Ingeniería Social.



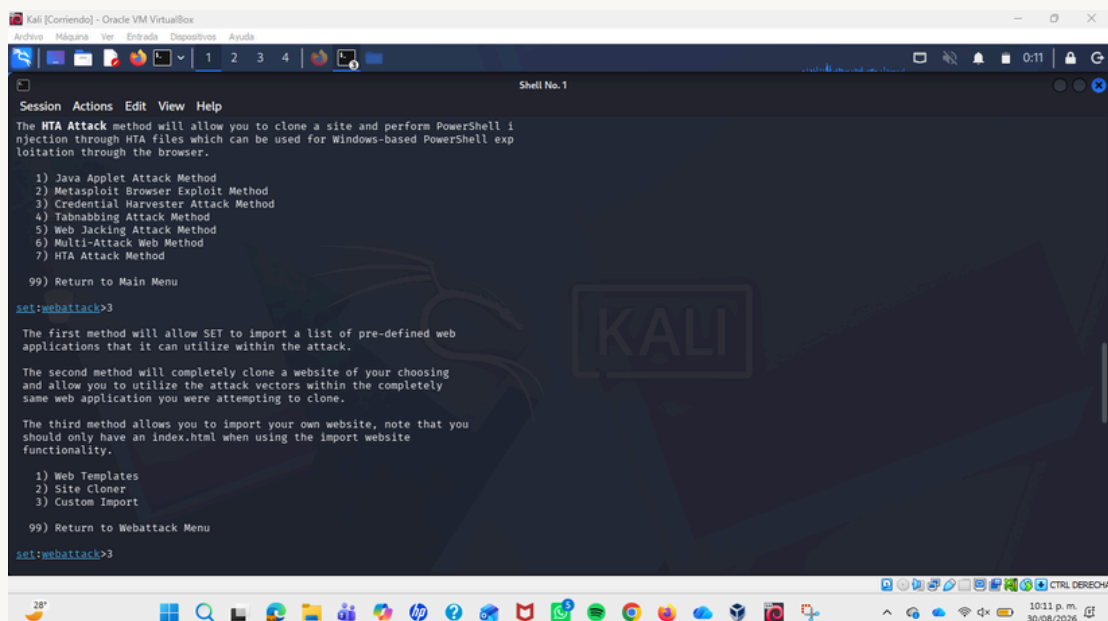
Ahora se muestra el siguiente menú en el cual seleccionamos la segunda opción la cual es, Ataque a Sitio Web.



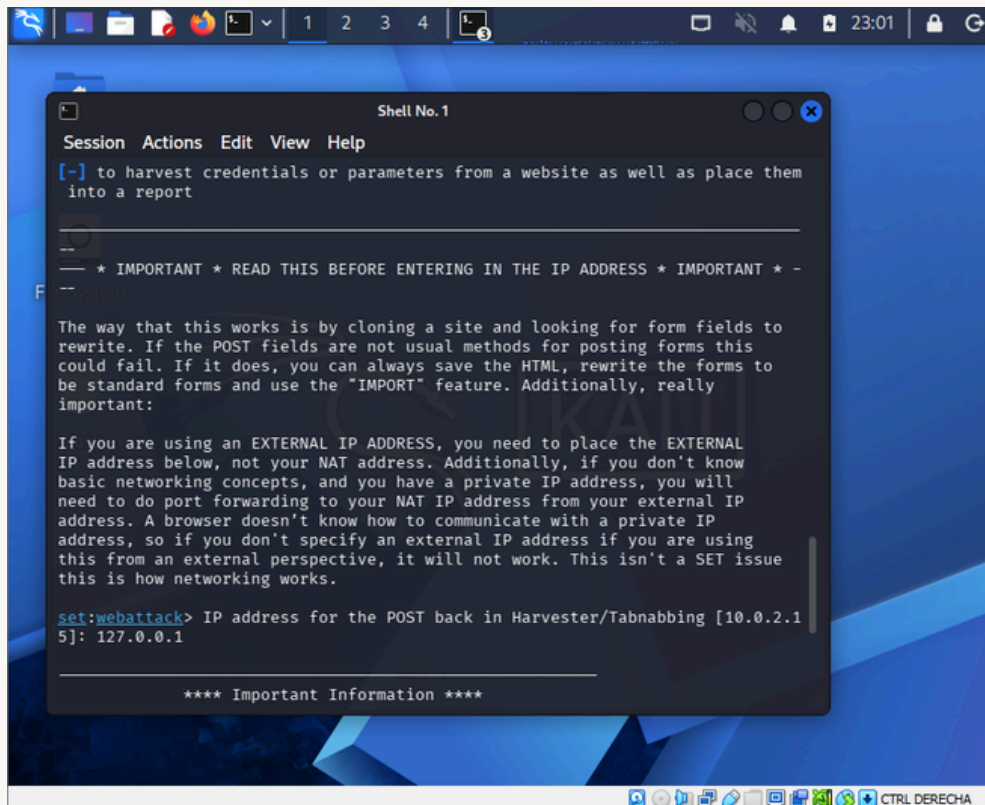
Ahora se muestra el siguiente menú en el cual seleccionamos la tercera opción la cual es, Ataque por medio de Credential Harvester. **¿Qué es Credential Harvester?** es una técnica de ciberataque, en la cual se recolectan credenciales de usuario, nombres, direcciones de correo electrónico, contraseñas, para realizar actividades sin consentimiento.



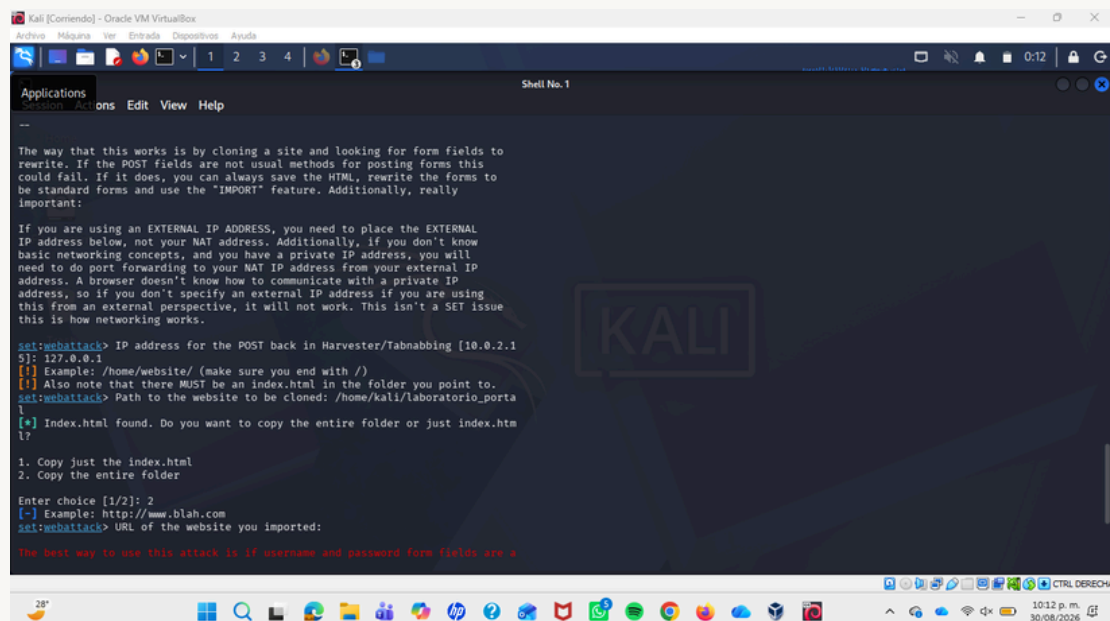
En el siguiente paso seleccionamos la tercera opción en donde importamos una página de nuestra preferencia.



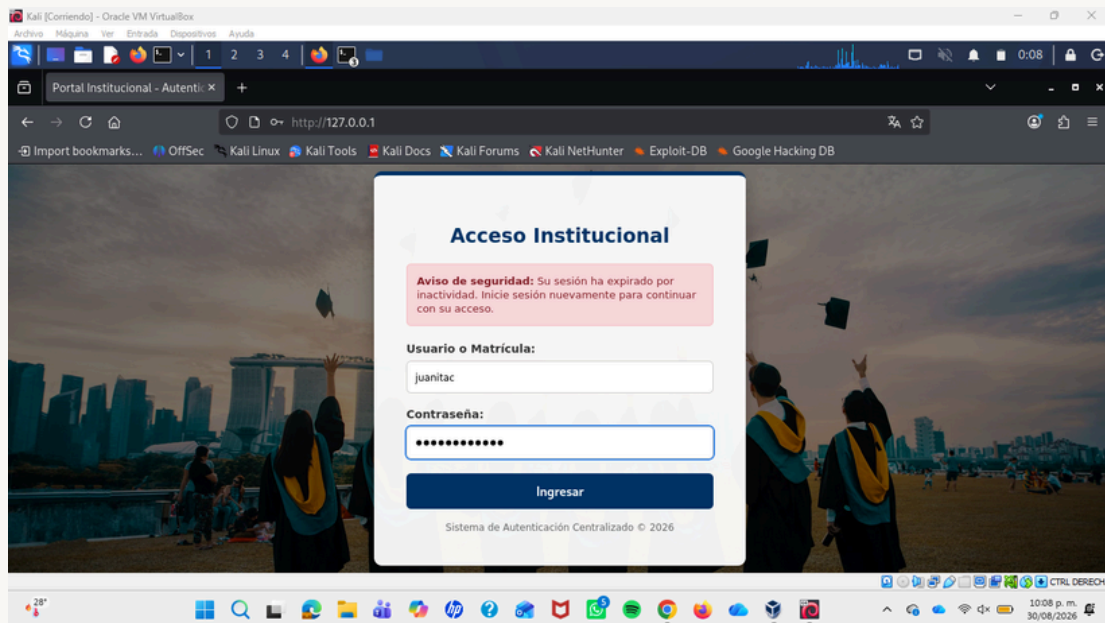
Seguimos con la configuración, en esta sección nos pide la dirección IP de nuestra página, la cual utilizamos la 127.0.0.1, **¿por qué esta dirección IP?** esta dirección IP es una dirección de bucle local, lo que significa que solo hay comunicación en la propia máquina virtual, lo que significa que esta no tiene conexión con lo exterior.



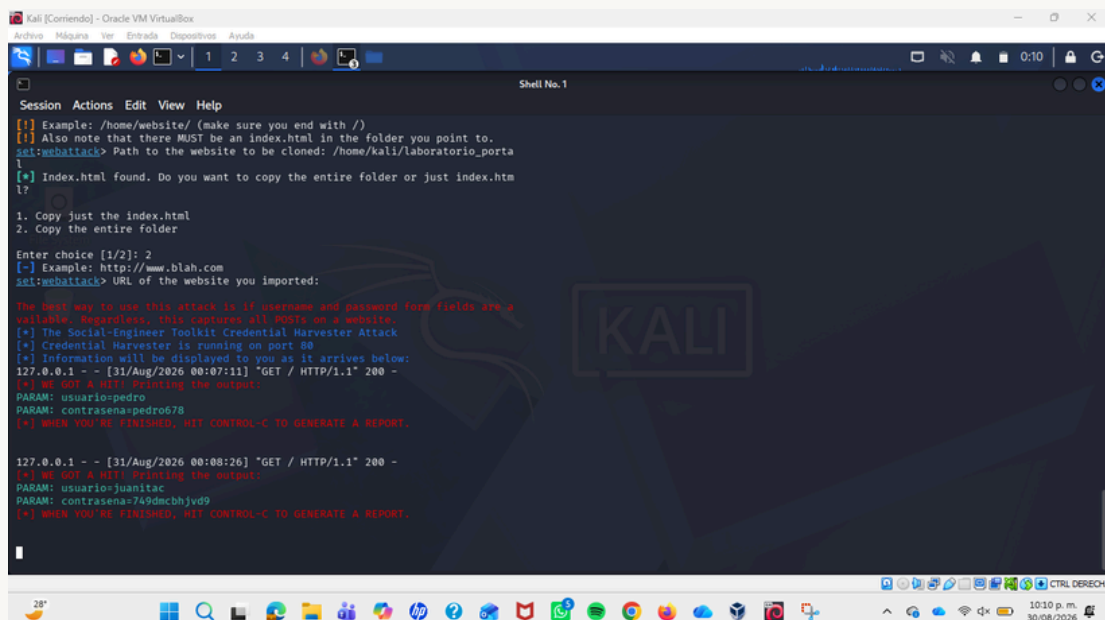
Ahora nos pregunta que si solo queremos que se copie solo el archivo index.html o si toda la carpeta, lo que seleccionamos es la opción de toda la carpeta para que también tome el script.



Ya que tenemos todo lo del SET configurado, ahora abrimos nuestra página, lo que significa que ahora ya registra las credenciales que se ingresen.



Nos movemos a nuestra terminal, donde hicimos la configuración, ahora podemos observar que cualquier credencial que se ingrese se muestra en nuestra terminal, por lo que si se realiza en una página que está en un servidor público, los datos ingresados serán vistos por atacantes que los utilizarían para acciones malignas.



CONTROLES DE SEGURIDAD PROPUESTOS.

- Desconfía de correos no solicitados o de desconocidos: Elimínalos directamente y bloquea al remitente.
- No respondas ni compartas información: Nunca envíes datos personales, credenciales o información bancaria a través de estos medios.
- Verifica los remitentes y enlaces: Comprueba siempre la autenticidad del mensaje antes de hacer clic en cualquier enlace o proporcionar datos confidenciales, incluso si aparenta venir de un contacto conocido.
- Evita descargas sospechosas: No abras archivos adjuntos de origen dudoso, ya que pueden contener código malicioso o malware.
- Mantén sistemas actualizados: Usa software de seguridad actualizado (como antivirus) y mantén tus dispositivos y programas al día.
- Activa la Autenticación de Doble Factor (2FA): Configúrala siempre que esté disponible en tus servicios en línea para añadir una capa extra de protección en tus cuentas.

CONCLUSIÓN

El desarrollo de esta práctica permitió comprender de manera práctica el funcionamiento de los ataques de ingeniería social, específicamente el uso de herramientas automatizadas como el Social-Engineer Toolkit (SET) combinadas con interfaces web personalizadas para la recolección de credenciales (Credential Harvester). A través del despliegue en un entorno local y controlado (127.0.0.1), se evidenció la vulnerabilidad fundamental a la que se enfrentan los usuarios ante la suplantación de identidad visual y la falta de verificación en las plataformas de autenticación.

Asimismo, se constató que la concientización humana y la adopción de medidas técnicas avanzadas son indispensables. Dependrer exclusivamente de la precaución del usuario es insuficiente, por lo que la implementación de controles de seguridad robustos –tales como la autenticación multifactor (MFA) resistente a phishing, protocolos estrictos de validación de correo y una cultura continua de ciberseguridad– resulta crucial para mitigar eficazmente estos vectores de ataque y proteger los activos de información institucionales.

REFERENCIAS

- INCIBE (Instituto Nacional de Ciberseguridad):
- Referencia: INCIBE. Cómo evitar ser víctima de phishing. Recuperado de <https://www.incibe.es/node/485661>.
- IBM (Think Topics):
- Referencia: IBM. Ingeniería social: Qué es y cómo prevenirla. Recuperado de <https://www.ibm.com/mx-es/think/topics/social-engineering>.
- CrowdStrike (Cybersecurity 101):
- Referencia: CrowdStrike. Credential Harvesting: What It Is and How to Prevent It. Recuperado de <https://www.crowdstrike.com/en-us/cybersecurity-101/cyberattacks/credential-harvesting/>.
- TrustedSec (Herramientas Oficiales):
- Referencia: TrustedSec. The Social-Engineer Toolkit (SET). Recuperado de <https://trustedsec.com/resources/tools/the-social-engineer-toolkit-set>.